MARKET AURA 4U

Product, Platform & AI Systems — Authoritative Engineering Source of Truth

Document ID: MA4U-ARCH-001 **Version:** 1.0 **Status:** Proposed target-state architecture and delivery plan **Factual baseline:** *Market Aura 4U — Complete System Architecture, Technical Audit, Implementation Status & Production Lifecycle Report*, v2.1.0, audit date November 2026 (8 pages). **Audience:** Founder, product, frontend, backend, ML/AI, platform, security and QA engineering.

> ***Hard constraint:*** *This document recommends changes. It does not authorize direct edits to existing model code. Treat existing model definitions as immutable for this planning exercise. Any future schema change requires a separately approved, additive migration proposal with compatibility, backfill, rollback and risk documented first.*

0. Authority, evidence and interpretation

0.1 Source of truth

The attached report is the factual baseline. It identifies Node 22 LTS, React 19, Python 3.11 and MongoDB 7; 513 reported automated tests; containerization; and a “Production Ready & Hardened” audit verdict.

The report is an audit summary, not the full source tree. Accordingly:

- **Report fact** means explicitly stated in the report.
- **Report limitation** means explicitly marked simulated, mocked, degraded, deferred or excluded.
- **Engineering inference** means a conclusion that must be checked against the actual repository.
- **Proposed decision** is a future recommendation, not a claim about current code.
- **Founder decision** is a product/business choice engineering must not silently make.

The report is internally nuanced: it calls the MVP production-ready, while also explicitly identifying simulated broadcast, mock-tested scheduling, deferred live analytics, provider approval dependencies, and deferred workspace/RBAC work. The correct interpretation is that the current MVP may be deployable, but the full agency-grade control centre requested here is not yet complete.

0.2 What “production ready” means in this document

A passing unit/integration suite and container build are necessary, not sufficient, for production readiness. Real provider credentials and approvals, live publish receipts, queue durability, tenant isolation, quota handling, privacy workflows, operational alerts, backups/restore drills and real load measurements must be evidenced independently.

1. Executive summary and business strategy

1.1 Product thesis

Market Aura 4U should become the **marketing operations control centre** for an individual, brand or agency: one shared website to plan, create, approve, schedule, publish, measure and improve organic social content across connected channels.

The product is not simply an AI caption generator. Its core loop is:

```
Workspace + brand
   → connect approved channels
   → plan content and campaigns
   → generate recommendations and drafts
```

```
→ edit / review / approve
→ schedule / publish
→ measure provider-backed results
→ improve future recommendations
```

The customer promise:

1. One brand-aware workspace for voice, audience, goals, assets and channels.
2. One content workflow from brief through publication and measurement.
3. One cross-channel view with provider-specific capabilities and limitations represented honestly.
4. AI as an accountable copilot, not an unbounded autonomous operator.
5. Recommendations that distinguish measured facts, derived metrics and generated hypotheses.

1.2 Target segments and sequence

Segment	Job to be done	Required capabilities	Sequence
Individuals / creators	Maintain a consistent presence without an agency	Personal brand, connections, AI studio, calendar, publishing, basic analytics	First
SMB / D2C brands	Coordinate brand-safe multi-channel marketing	Brand profile, assets, approvals, scheduling, analytics, usage/billing	First / second
Boutique agencies	Manage multiple client brands and collaborators	Workspaces, client separation, roles, approvals, campaign reporting	Second
Enterprise	Govern many brands, teams, approvals and integrations	Advanced RBAC, SSO, audit export, policy controls, SLAs, procurement	Later; validate demand

The report names solopreneurs, SMB/D2C marketers and boutique agencies as current target personas. It explicitly defers multi-brand UI and team RBAC to v1.3. Recommended sequencing is individual/SMB reliability first, agency tenancy second, enterprise governance only after validated demand.

1.3 Product scope

Core modules:

- Workspace and brand identity
- Social account connections
- Content library and calendar
- AI Studio and recommendation centre
- Approval and collaboration
- Campaign planning and execution
- Scheduling and publishing
- Media library
- Analytics and reporting
- SEO and organic-growth recommendations
- Billing, credits and usage
- Settings, notifications, audit and integrations

Do not initially promise:

- replacement of every native social/ad manager;
- guaranteed growth, reach, engagement or search rankings;
- autonomous publishing or spending without approval;
- every social platform before access and operational support are proven;
- paid-ad buying in the same release as organic social management;
- model training on customer data without explicit opt-in and legal review.

1.4 Monetization

The report lists these existing plan values:

Plan	Reported price	Monthly credits	Reported included capabilities
Starter	■499	100	1 brand; AI Studio for LinkedIn/X/Instagram/Email; copy/export; simulated broadcast
Pro	■1,499	500	Starter + 3 connected channels, ML recommendations, scheduling queue, media library
Enterprise	■4,999	2,500	Pro + priority Groq inference, unlimited channels, full media assets, custom voice guidelines

These are report-reported prices, not validated willingness-to-pay or proven margin-safe prices. ■4,999 may not match enterprise procurement/support expectations. **Recommendation:** consider renaming this tier “Business” until enterprise governance, support and SLA exist. Do not change price points without measured usage, conversion, retention and provider costs.

Revenue options:

- recurring subscription as primary revenue;
- credits for variable-cost AI operations;
- additional seats and brands/workspaces for agency plans;
- premium analytics/reporting only after trustworthy metrics exist;
- AI automation add-ons only after agent cost and outcomes are measured;
- enterprise annual contracts only when security, governance and support justify them.

Unit economics

The report says one multi-platform generation consumes one credit atomically. It does not provide invoice data, token usage, storage, activity distribution, support cost or infrastructure sizes. Therefore no factual gross-margin figure can be computed.

```
Gross profit/account
= subscription + usage/add-on revenue
- LLM and ML inference
- worker/API/database/queue compute
- storage and egress
- payment processing
- provider/API costs
- attributable support and operations

Gross margin = (revenue - cost of goods sold) / revenue
```

Instrument cost per generation, tokens/retries, agent run/tool calls, media GB-month and egress, provider calls, analytics polling, payment fees, refunds and support time. Avoid unbounded “unlimited AI” entitlements.

1.5 Build versus reuse

Capability	Decision	Rationale
Tenant, brand, content and approval domain	Build	Core product differentiation and data boundary
Existing React SPA	Extend	Report says responsive, themed and tested
Existing Node/Express API	Extend	Existing auth, settings, billing and orchestration
CAPSTONE recommender	Reuse behind FastAPI contract	Existing Python service and fallback
Social APIs	Official APIs + internal adapters	Avoid unofficial automation and provider leakage
Token encryption	Retain, verify lifecycle and key rotation	AES-256-GCM reported
Queue	Verify existing code; use BullMQ/Redis if absent/incomplete	Report explicitly proposes BullMQ for analytics
Razorpay	Reuse	Test-mode order and HMAC flow reported
Media binary storage	Object storage	Report confirms media UI/API but does not name backing storage
Agent orchestration	Build narrow internal workflow layer	Keep permissions and audit in control plane
Search	Mongo indexes first	Avoid search infrastructure before measured need

2. Current-state assessment and defect ledger

2.1 Implemented and verified according to report

Page 4 lists:

- Auth/session: signup/login/logout, normalized email, bcrypt cost 12, HttpOnly cookie.
- Brand onboarding wizard.
- Dashboard: credits, subscription, connected channels, studio launcher, brand summary.
- Groq AI Studio for LinkedIn, Twitter/X, Instagram and Email; atomic credit deduction.
- Manual broadcast composer and character counters; **instant broadcast is simulated**.
- Content history with search, platform badges, copy/export and paginated infinite scroll.
- Scheduling calendar/list; **tested with mock data**.
- Media library: uploads, thumbnails, metadata, delete and attach.
- Social connections UI for X, LinkedIn, Instagram, Facebook and Email.
- Eight-tab settings suite.
- Light/dark/system theme.
- Viewport virtualization and static sidebar layout.

Page 3 lists auth, onboarding, generation/history, payments and settings endpoints. Media, scheduling, dashboard and social routes are described elsewhere but not fully enumerated in the API table.

2.2 Partial, simulated or deferred

Capability	Report status	Consequence
ML recommendations	CAPSTONE FastAPI with deterministic heuristic fallback	UI and logs must expose fallback/provenance
Live publishing	X API v2 and Instagram Graph API code paths; staging/demo may simulate success without credentials	Verify real approved account publishing before marketing as live
Razorpay	Real order/HMAC flow in test mode	Live KYC and live keys still required
Manual broadcast	Simulated instant broadcast	Never label simulation as published
Scheduling	Mock-tested calendar/queue	Durable schedule, worker dispatch and cancellation require E2E proof
Analytics	Live ingestion deferred to v1.2	No “real-time analytics” claim until provider ingestion exists
Cross-network publishing	Deferred to v1.1 pending Meta/LinkedIn access	Provider approval is a delivery dependency
Multi-brand	Brands collection described as decoupled by userId; UI supports one active brand	Workspace/brand switcher remains
Team/RBAC	Deferred to v1.3	Agency collaboration not shipped
ML retraining	Deferred	Do not auto-train on customer data
Video/Reels and Zapier/Make	Deferred to v1.4	Separate future workstreams

2.3 Historical defects the report says are fixed

These are regression controls, **not confirmed current bugs**.

ID	Historical defect	Reported fix	Reproduction / regression
CON-01	targetAudience treated as object although stored as string; prompt contained `undefined`	Handles string/object formats, pain points/desires up to 500 chars	Submit both forms; assert valid prompt and no `undefined`
GEN-01	No upfront credit check/decrement	402 `INSUFFICIENT_CREDITS`, atomic decrement	Zero balance: 402/no provider call. Concurrent balance=1: exactly one success
SEC-03/04	Client amount/plan trusted; verification trusted userId and lacked constant-time check	Server PLANS catalog, ownership/session binding, `timingSafeEqual`	Tamper price, plan, userId and signature; no entitlement change

ID	Historical defect	Reported fix	Reproduction / regression
SEC-01/02	Legacy route/controller used raw userId OAuth state and mock credentials	Legacy file removed; signed single-use state	Alter, replay and expire state; callback rejects
E2E-01	Hardcoded Windows Python path broke macOS/CI	Cross-platform executable discovery	Run on Linux/macOS/Windows
FE-02	Reload required localStorage token despite valid cookie	Cookie session restore via profile request	Clear local storage, retain cookie, reload
FE-03	Dark-only styles	Light/dark/system tokens	Verify all modes and no flash
FE-05	Settings page missing	Eight tabs + REST endpoints	Navigate and save each settings tab

Severity grouping in the report:

- S0: unauthorized publishing, OAuth state forgery, client-controlled payment pricing/verification.
- S1: token exposure, CORS, dual auth, NoSQL injection, rate limits, SSRF, error leakage, prompt injection, cookie security and credit enforcement.
- S2: dependency hygiene and email normalization.

The report says SEC-01–SEC-19 are remediated but the visible table describes SEC-01–SEC-15 and SEC-17. SEC-16, SEC-18 and SEC-19 are not detailed in the report text available here. Obtain the detailed evidence; do not invent their contents.

2.4 Remaining actionable gaps (not assertions of current bugs)

Priority	Gap requiring proof/work	Why	Concrete acceptance
P0	Simulation vs real publish semantics	False success damages trust	Distinct states `simulated`, `queued`, `provider_accepted`, `published`, `failed`; production cannot enable simulation
P0	Scheduling is mock-tested	UI does not prove durable scheduling	Persist, dispatch, retry, cancel race and duplicate prevention across restart
P0	OAuth refresh/revocation details not complete in report	Expired token can break scheduled post	Per-provider refresh, expiry, revocation, key rotation and reconnect tests
P0	Tenant isolation not demonstrated	Cross-customer data exposure	Negative tests for every tenant-owned resource and worker
P0	Agent approval not described	Agent could damage public brand or spend	Draft-only default; approval-bound side effects
P1	Campaign domain not described as implemented	Required product capability	Define campaign after content/schedule primitives
P1	Live analytics explicitly deferred	No defensible reporting yet	Provider-backed ingestion and freshness
P1	SEO module not described	Product requirement beyond current CAPSTONE	Evidence-labelled content recommendations
P1	RBAC/team deferred	Agency workflow incomplete	Workspace memberships and roles
P1	Queue presence not confirmed	Reliable retries need durable workers	Inspect; introduce/extend BullMQ if needed
P1	Provider quotas not detailed	Shared quota exhaustion	Per-provider rate buckets and backpressure
P1	Cost attribution absent	Unit economics unknown	Per-generation/agent/provider cost ledger
P2	Index/query plan not detailed	Scale risk	Inspect actual queries and `explain()`
P2	Retention/GDPR workflows not described	Compliance gap	Data inventory, export/delete and retention
P2	Alerts/SLOs not detailed	Tests do not prove operations	Dashboards, alerts, incident/rollback runbooks

2.5 Test baseline caveat

Report page 7:

- backend: 449/449;
- frontend: 37/37;
- ML: 26 passed, 1 skipped out of 27;
- TypeScript clean;
- ESLint clean;
- Prettier compliant;

- Vite build 42 chunks, 303 ms;
- deployment verifier 10/10.

This is a strong baseline. The ML suite has one skipped test, so “100%” is the report's presentation rather than every test executing. Tests do not prove platform production approvals, live account publishing, quota headroom, disaster recovery or real traffic capacity.

Next action: reproduce the tests from an exact commit SHA in CI and archive logs, coverage, provider sandbox evidence and deployment verifier output. The report does not include a commit SHA or raw test artifacts.

3. Target architecture

3.1 Decisions and rationale

1. **One shared SaaS app with strict tenant context.** Users share the same site; authorization and data are workspace-scoped.
2. **Modular monolith for the control plane.** Keep Node/Express initially; split services only for measured scaling, deployment, runtime or reliability boundaries.
3. **Separate async workers.** Publishing, scheduling, analytics and agent runs must not depend on an open HTTP request.
4. **Python remains the ML runtime.** Report already describes FastAPI on port 8080.
5. **Provider adapters isolate platform APIs.** Provider payloads must not become the canonical content model.
6. **Human approval for irreversible actions.** Publish, delete live posts, bulk email, campaign activation with external effects, and any spending require explicit approval.
7. **Every recommendation carries provenance.** Model/version, data window, source, freshness and uncertainty.
8. **No silent simulation.** Mock adapters are development/test-only and cannot report live success.

3.2 Logical topology

```
React SPA
  ■■ workspace/brand switcher
  ■■ content, calendar, campaigns, analytics
  ■■ AI Studio + approvals
  ■■ settings/billing
          ■ HTTPS + HttpOnly session
          ▼
Node/Express control plane
  ■■ identity/session + tenant authorization
  ■■ brand/content/campaign/approval
  ■■ social connections + provider adapters
  ■■ publishing + billing/usage
  ■■ analytics API
  ■■ agent orchestrator + tool policy
       ■■■ MongoDB 7
       ■■■ Redis/BullMQ (proposed; verify current code)
       ■■■ Python FastAPI CAPSTONE
       ■■■ Groq LLM (currently reported)
       ■■■ X / Meta / LinkedIn / Email adapters
       ■■■ Razorpay
       ■■■ object storage
       ■■■ logs/metrics/traces
```

3.3 Deployment

Report confirms Docker artifacts for frontend Nginx, Node backend, Python ML, Docker Compose with frontend/backend/recommender/mongo, Render spec, Vercel config and health checks.

Proposed next topology:

- web: static SPA on CDN/Nginx;
- API: stateless Node containers;
- worker: separate Node process using shared domain code;
- ML: private FastAPI service;
- MongoDB: managed replica set, backups and restore drills;
- Redis: managed/durable service for BullMQ;
- media: object storage with signed URLs;

- secrets: managed secret store/platform secrets;
- observability: structured logs, metrics, traces and error reporting.

Rejected for now: Kubernetes by default. Existing Docker/Render/Vercel approach is adequate until measured workload or operational requirements justify cluster orchestration.

3.4 Domain boundaries

Module	Owns	Does not own
Identity	users, sessions	brand content
Workspace	tenant, membership, role policy	provider token refresh
Brand	voice, audience, goals, guidelines	authentication
Social connections	OAuth, credentials, account metadata	content lifecycle
Content	drafts, versions, platform variants, assets refs	provider HTTP details
Campaigns	objective, brief, dates, grouping, status	provider-specific publishing
Approvals	request, decision, policy	agent planning
Publishing	dispatch, retries, receipts, idempotency	billing plan catalog
Analytics	normalized metrics, reports	token storage
Recommendations	CAPSTONE/LLM output + provenance	autonomous publishing
Agents	bounded plans/tools/checkpoints/traces	unrestricted DB/API access
Billing	plans, payment, entitlement, usage	client price authority

3.5 Provider adapter contract

```
interface SocialProviderAdapter {
  getAuthorizationUrl(context): Promise<AuthorizationRequest>;
  exchangeAuthorizationCode(input): Promise<TokenSet>;
  refreshCredentials?(connection): Promise<TokenSet>;
  revoke?(connection): Promise<RevocationResult>;
  getAccountIdentity(connection): Promise<ProviderIdentity>;
  publish(input): Promise<PublishReceipt>;
  deletePost?(providerPostId, connection): Promise<DeleteReceipt>;
  fetchMetrics?(providerPostId, connection): Promise<NormalizedMetrics>;
  getCapabilities(): ProviderCapabilities;
}
```

Capabilities must be explicit/versioned: text, image, video, carousel, link, delete, analytics, native scheduling, token refresh and webhook support. Do not assume every platform supports every action or grants access to every developer app.

4. Database design and migration — suggestions only

4.1 No model-code modification

The report describes User, embedded Brand Profile, Job/Generation Archive and Social Account subdocuments. It also says a brands collection is decoupled by userId, while the UI currently supports one active brand. This section proposes **logical entities and additive migrations only**. Inspect actual models and indexes before implementation. Do not rewrite `User.js` or `Job.js` under this mandate.

4.2 Tenant model

Decision: use `Workspace` as the security boundary and `Brand` as a marketing identity inside a workspace. An individual starts with one default workspace; agencies can manage multiple client workspaces/brands.

```
User
  ■■ WorkspaceMembership ■ Workspace
                             ■■ Brand
                             ■■ SocialConnection
                             ■■ ContentItem / ContentVersion
                             ■■ Campaign / CampaignContent
                             ■■ ApprovalRequest / Decision
                             ■■ Schedule / Publication
                             ■■ MediaAsset
                             ■■ AnalyticsSnapshot
```

```
                    ■■ Recommendation / AgentRun
                    ■■ UsageLedgerEntry / Subscription
                    ■■ AuditEvent
```

4.3 Proposed entities

Entity	Conceptual fields	Purpose
Workspace	id, name, owner, plan, status	Tenant boundary
WorkspaceMembership	workspaceId, userId, role, status, invitedBy	User authorization
Brand	workspaceId, name, industry, voice, audience, goals, channels	Marketing identity
SocialConnection	workspaceId, brandId, provider, providerAccountId, encrypted token envelope, scopes, expiry, status	Provider credentials
ContentItem	workspaceId, brandId, ownerId, title, status, tags, folderId	Canonical content
ContentVersion	contentItemId, platform, body, media refs, version, author	Immutable variants
Campaign	workspaceId, brandId, objective, dates, status, owner	Campaign lifecycle
CampaignContent	campaignId, contentItemId, slot/role	Content grouping
ApprovalRequest	objectType/id, requester, policy, status, expiry, actionHash	Human gate
ApprovalDecision	approvalId, actorId, decision, comment, timestamp	Immutable decision
Schedule	contentVersionId, connectionId, scheduledAtUtc, timezone, status	Planned dispatch
Publication	schedule/contentVersion, providerPostId, status, attempts, receipt	External side effect
MediaAsset	workspaceId, storageKey, mime, size, checksum, metadata	Binary metadata
AnalyticsSnapshot	publicationId, provider, metrics, collectedAt, freshness	Normalized performance
Recommendation	workspaceId, brandId, input snapshot, output, modelVersion, evidence	Provenance
AgentRun	workspaceId, agent, goal, plan, state, traceId, cost, approvals	Agent observability
UsageLedgerEntry	workspaceId, actor, operation, units, cost, idempotencyKey	Auditable usage
AuditEvent	workspaceId, actor, action, target, timestamp	Accountability

These are conceptual proposals, not a requirement to add every collection at once.

4.4 Index candidates

Validate with real query patterns and Mongo `explain()` before creating indexes:

- WorkspaceMembership unique `{workspaceId,userId}`; lookup `{userId,status}`.
- Brand `{workspaceId,status,createdAt}`.
- SocialConnection `{workspaceId,provider,status}` and provider identity uniqueness where provider semantics permit.
- ContentItem `{workspaceId,brandId,status,updatedAt}`.
- ContentVersion `{contentItemId,createdAt}`.
- Schedule `{status,scheduledAtUtc}` and `{workspaceId,scheduledAtUtc}`.
- Publication unique idempotency key; `{workspaceId,status,createdAt}`.
- Campaign `{workspaceId,status,startAt}`.
- AnalyticsSnapshot `{publicationId,collectedAt}`.
- UsageLedgerEntry `{workspaceId,createdAt}` and unique idempotency key.
- AuditEvent `{workspaceId,createdAt}`.

Use TTL only for explicitly ephemeral records such as OAuth state. Do not TTL-delete payment, audit or publication history by default.

4.5 Tenant isolation

- Resolve workspace from authenticated session and membership; never trust body-supplied workspaceId for authorization.
- Every tenant-owned query includes workspaceId.

- Every job includes workspace, actor/system identity, resource ID/version and trace ID.
- Workers re-check authorization/capability before side effects.
- Signed media URLs are tenant-scoped and short-lived.
- Admin/support access is least-privileged and audited.
- Add negative tests: Workspace A cannot read/write Workspace B content, assets, campaigns, analytics, connections, jobs or billing records.

4.6 Token storage and refresh

The report says social tokens use AES-256-GCM, `select:false`, and `TOKEN_ENCRYPTION_KEY`.

Proposed hardening:

- store ciphertext, nonce/IV, authentication tag, key version and metadata as a token envelope;
- keep keys outside MongoDB and source control;
- prefer managed KMS/envelope encryption when available;
- document key rotation and re-encryption procedure;
- store granted scopes, expiry, last refresh, last validation and revocation state;
- never return tokens to browser or logs;
- refresh proactively under a per-connection lock;
- on permanent refresh failure, mark `reauthorization_required`, pause dependent schedules and notify owner;
- on disconnect, revoke at provider where supported, then invalidate/delete credentials and retain non-secret audit event.

4.7 Additive migration plan

1. Inventory actual collections, schemas, indexes, references and data volume.
2. Add Workspace/Membership collections without changing existing model definitions.
3. Backfill each user to one default workspace and map current brand profile to Brand.
4. Keep deterministic mapping table and dry-run report.
5. Dual-read with legacy fallback during bounded transition.
6. Dual-write only where needed; detect divergence.
7. Reconcile counts, ownership, content links, social associations and checksums.
8. Switch reads to new tenant-scoped records.
9. Stop legacy writes after all clients/workers migrate.
10. Any later removal of legacy fields is a separate approval outside this constraint.

Risk: incorrect tenant mapping and dual-write divergence. Mitigate with idempotent scripts, dry run, backups, checksums, reconciliation and feature-flag rollback.

---

5. Security, platform compliance and privacy

5.1 Reported controls

The report states SEC-01–SEC-19 remediated and explicitly describes:

- authenticated publishing; legacy unauthenticated Instagram route removed;
- signed, single-use, expiring OAuth state;
- server-authoritative payment plan catalog and constant-time HMAC verification;
- `select:false` for secrets;
- Node native crypto;
- explicit CORS allowlist;

- cookie-only session model;
- input sanitization/ObjectId validation;
- rate limits for signup/login/generation;
- normalized email;
- AES-256-GCM token encryption;
- media URL scheme restriction and loopback blocking (SSRF mitigation);
- sanitized production errors;
- prompt-injection mitigations;
- HttpOnly/SameSite/Secure cookies.

Retain regression tests. The report does not describe SEC-16, SEC-18 or SEC-19 individually.

5.2 OAuth scopes

The report does not enumerate exact scope strings or prove which provider permissions are approved. Do not invent them. Create a versioned permission matrix from current official provider documentation and the app's actual approved access.

Provider	Capability intent	Required verification
Instagram/Meta	professional account identity, permitted publishing and insights	account type, Page linkage, app review, advanced access and exact permission names
Facebook Pages	Page identity, publish to authorized Page, permitted insights	Page access model, user role, app review and Page permissions
LinkedIn	member/org identity, publish for authorized identity, analytics if approved	partner/product access and organization authorization; report notes enterprise contracts
X	identity, create/delete posts, read metrics if entitlement allows	developer tier, write/read quotas, OAuth requirements
Email	send via email provider	verified sender/domain, consent, unsubscribe and suppression rules; not social OAuth

OAuth flow:

```
authenticated user
 → explain permissions
 → create random state + PKCE where supported
 → persist short-lived, single-use state bound to session/workspace/provider
 → provider authorization
 → validate callback state, expiry and redirect
 → exchange code server-side
 → fetch provider identity
 → encrypt/store token + scopes/expiry
 → audit and display connection status
```

Never trust callback-supplied user/workspace IDs or arbitrary redirect URLs. Tokens never reach frontend.

5.3 Rate limits and provider quotas

Three layers:

1. Application rate limits per user/workspace/IP for auth, generation, media, agent runs and mutations.
2. Provider quota scheduler per provider/app/account/endpoint, respecting response headers and `Retry-After`.
3. Cost/abuse budgets: credits, AI tokens, agent steps, recipients and media.

On quota exhaustion, defer rather than spin; show “waiting for platform quota,” retain last-known state and alert ops when many tenants are affected.

5.4 GDPR and data governance

The report does not state a GDPR program, DPA, data residency, retention or deletion workflow. Treat these as open work.

Required:

- data inventory and purposes;
- privacy notice, terms and subprocessors list;
- DPA where required;

- export and deletion workflow;
- retention by data class;
- deletion/anonymization after legal/contractual retention;
- backup expiry/deletion behavior;
- cross-border transfer review;
- data subject request audit;
- email consent/unsubscribe/suppression;
- default no training on customer content absent explicit opt-in and legal review.

Do not promise retention/deletion behavior until implemented. Do not store unnecessary provider payloads or personal data.

5.5 Abuse prevention

Per-tenant quotas, bot/signup controls, prompt/output safeguards, bulk email protections, sender verification, platform policy checks, OAuth anomaly detection, immutable approvals/audit and kill switches per provider/tenant/automation class.

6. Scalability and cost projections

6.1 Workload profile

The report provides no MAU, concurrency, average generation volume, post volume, media size, polling frequency or instance sizes. The following are planning scenarios, not forecasts.

Expected workload:

- read-heavy dashboard/history/calendar/analytics;
- bursty LLM generation;
- scheduled publish bursts;
- provider-quota-limited outbound requests;
- media upload/download;
- periodic analytics ingestion;
- multi-step agent workflows.

6.2 Bottlenecks and response

Workload	Likely bottleneck	Response
Dashboard/history	Mongo query/index, payload size	tenant/date indexes, pagination, short-lived aggregate cache
Generation	LLM latency, quotas and token cost	bounded concurrency, async path, timeouts, circuit breaker
ML	Python CPU/memory and concurrency	independent FastAPI scaling
Publishing	provider quota/network ambiguity	queue, idempotency, per-provider limiter
Scheduling	due-job scans and bursts	durable delayed jobs and schedule records
Analytics	API quota and polling volume	incremental polling, backoff, freshness windows
Media	storage/egress	object storage, CDN, signed URLs, size limits
Agents	multi-step LLM/tool cost	max steps, budgets, allowlisted tools, approvals

6.3 Caching

Cache dashboard aggregates and analytics summaries by workspace with short TTL and explicit `asOf`; cache provider capability metadata and per-run brand context. Never cache decrypted tokens in shared cache. Invalidate on workspace writes or membership/role changes. Do not cache authorization decisions without a revocation strategy.

6.4 Background jobs

Queues: `publish`, `schedule`, `analytics-ingest`, `agent-workflow`, `media-processing`, `notifications`, `token-maintenance`.

Each job carries job ID, idempotency key, workspace, actor/system identity, resource ID/version, provider/account key, trace ID, scheduled time and attempts. Use bounded concurrency, exponential backoff+jitter, `Retry-After`, dead-letter queues and reconciliation. Never blindly retry a publish with ambiguous provider outcome.

6.5 Horizontal scaling path

1. Current reported containers: frontend/backend/recommender/Mongo.
2. Split API and worker process roles.
3. Use managed/durable Redis for BullMQ if not already present.
4. Scale stateless API replicas; eliminate process-local authoritative state.
5. Scale worker pools by queue depth and provider quotas.
6. Scale ML independently by latency/CPU/memory.
7. Add object storage/CDN.
8. Add analytics read models/aggregation when measured query load requires it.
9. Extract services only for proven independent scaling, runtime, ownership or reliability needs.

6.6 1k / 100k / 1M user scenarios

No exact monthly currency cost is defensible without workload and provider pricing. Use this scenario model:

Assumptions to validate: “users” means monthly active users; average generations per user/month low/base/high = 5/20/60; average posts per user/month = 5/20/60; media and analytics vary by plan. These are scenario assumptions, not report facts.

MAU	Generations/month (5 / 20 / 60)	Posts/month (5 / 20 / 60)	Architecture posture
1,000	5k / 20k / 60k	5k / 20k / 60k	modest API, separate worker, one ML service, managed Mongo/Redis, object storage
100,000	0.5M / 2M / 6M	0.5M / 2M / 6M	multiple API replicas, queue concurrency pools, ML replicas, CDN and analytics aggregation
1,000,000	5M / 20M / 60M	5M / 20M / 60M	region-aware design if needed, queue partitioning, dedicated analytics pipeline; DB partition/sharding only after evidence

Calculate:

```
AI cost = generations × avg input/output tokens × provider prices
        + agent runs × avg tokens/tool calls × blended price

Infrastructure = API + workers + ML + Mongo + Redis
               + object storage + CDN/egress + monitoring + backups

Provider operations = connected accounts × polling frequency × quota/request cost
```

Run a 30-day instrumented beta to fill the variables. One million registered accounts is not one million concurrent users; size to peak requests, scheduled bursts and provider quotas.

7. User flows and UX/UI

The report confirms dashboard, onboarding, AI Studio, history, schedule, media, social connections and eight settings tabs. The following extends those foundations.

7.1 Global shell

Navigation: Overview, Planner/Calendar, Content, Campaigns, AI Studio, Analytics, Media Library, Social Accounts, Approvals, Reports, Settings.

Top bar: workspace/brand switcher, global search, create button, notifications, help, profile/billing.

Navigation is permission-aware. A user without publish permission can draft but cannot publish. Users with multiple workspaces must always see active workspace context.

Global states:

• loading skeletons preserving layout;

- empty states with safe next action;
- permission denied with required role;
- provider unavailable/degraded;
- offline draft preservation where safe;
- stale data with last-updated time.

7.2 Onboarding

1. Sign up/login.
2. Create or join workspace.
3. Choose individual/brand/agency setup only if it changes required fields.
4. Create brand: name, industry, UVP, audience, tone, voice guidelines, goals.
5. Connect first channel or skip.
6. Create first content idea.
7. Explain approval/publishing permissions.
8. Dashboard with setup checklist.

Persist progress; allow skip/resume; OAuth failure must not lose brand data. Empty state for no channels explains requirements, not a fake “connected” state.

7.3 Social account connection

Provider cards show capability, account handle, status and available actions. Connect flow explains scopes, performs OAuth, validates state and identity, stores encrypted token, and displays granted scopes/health. Reauthorize/disconnect actions are explicit. Never show raw tokens.

Failure states: cancellation, app not approved, insufficient scope, token exchange failure, expired token, provider outage, unsupported account type.

7.4 Content create → approve → publish

Lifecycle:

```
Idea → Brief → Draft → Review → Approved → Scheduled → Publishing → Published
                                  ■ Rejected / Needs changes
```

Create:

1. choose workspace/brand and optional campaign;
2. enter brief;
3. select target channels;
4. request recommendations;
5. generate variants;
6. edit and attach media;
7. preview platform constraints;
8. submit for approval or approve if authorized;
9. schedule or publish now;
10. show provider receipt/status.

Content screen: title, brief, tags/folder, per-platform variants, version history, owner, comments, approval, destinations and audit trail.

Deleting a draft is distinct from deleting a live provider post. Local deletion must never imply provider deletion.

7.5 Calendar

Month/week/list, filters by workspace/brand/platform/campaign/status/owner, explicit timezone. States: draft, awaiting approval, scheduled, queued, publishing, published, failed, cancelled, blocked by reauthorization, waiting for quota.

Before dispatch, cancellation removes the job. During dispatch, show cancellation may be too late and reconcile. After publication, offer provider deletion only where supported and authorized.

7.6 Campaigns

Campaign is a coordinated collection of content and work, not just a tag.

Fields: name, objective (awareness/engagement/traffic/leads/community/launch), audience, message/offer, dates, channels, deliverables, owner/collaborators. Budget is planning metadata only until paid-media execution is separately approved.

Flow: brief → content plan → deliverables → assign → approve → schedule → monitor → report. Do not call ad APIs or spend funds in this phase.

7.7 Analytics

Views: workspace/brand overview, channel, post and campaign performance, reports. Each metric carries provider, definition, source timestamp, collection timestamp and freshness. Never show zero when unavailable; show unsupported or last synced.

7.8 Recommendations

Card includes statement, rationale/evidence, expected outcome as hypothesis, confidence/evidence strength where valid, data window, affected channel, estimated action/cost impact, Accept/Edit/Dismiss/Save. Accept creates a draft/proposed change, not an automatic publication.

7.9 SEO and organic growth

Start with content topic/keyword ideas, caption/hashtag relevance, content gaps, repurposing, cadence suggestions, alt-text/accessibility, UTM guidance and content quality checks. Do not claim live search volume, backlinks, ranking or competitor intelligence without licensed/connected data sources. Label generated ideas as suggestions, not measured demand.

8. Failure modes and fail-safes

Failure	Behavior	Retry/recovery	User communication
Social API down	Keep job pending/transient; never mark published	Backoff+jitter; respect Retry-After; dead-letter	Platform unavailable; next retry time
Token expires before post	Pause account jobs; try one safe refresh if supported	Per-connection refresh lock; reauthorize on permanent failure	Reconnect required
Refresh rotation race	Do not parallel-refresh same connection	Single-flight refresh; persist newest token version	Connection health warning
Duplicate schedule fires	Idempotency prevents second provider call	Reconcile publication record	One publication shown
Provider accepted but request timed out	State `unknown/reconciling`	Provider lookup/receipt reconciliation; manual review if unsupported	“Checking whether post went live”
Permanent publish failure	Preserve content; mark failed	User edits/retries; keep error details	In-app/email alert
Agent bad output	Draft only; validation/human review	Edit/regenerate; record rejection	Explain blocked issue
Agent unauthorized tool	Policy denies and audits	Terminate run; no automatic retry	Alert on suspicious attempt
LLM unavailable	Queue/retry or offer retry	Bounded retry, circuit breaker, approved fallback only	Delayed generation
ML unavailable	Use deterministic fallback only if configured	Retry; record fallback provenance	Label heuristic fallback
Payment fails	No entitlement activation	Retry checkout; reconcile provider status	Payment failed
Duplicate payment callback	Idempotent verification	Unique provider IDs	One activation only
Media upload interrupted	Mark incomplete	Resume or clean orphan after grace	Retry upload
Analytics quota exhausted	Preserve last-known metrics	Delay ingestion and backoff	Show stale timestamp
Mongo unavailable	Readiness fails; return dependency unavailable	Bounded reconnect; no destructive retry	Incident status
Queue unavailable	Do not claim schedule accepted	Retry enqueue/outbox after recovery	“Not scheduled yet”

8.1 Idempotency

Use stable keys for publish (workspace + content version + connection + slot), payment verification (provider payment/order), credit use (operation ID), agent execution (approval ID + action hash) and email batch sends.

8.2 Rollback reality

- Draft generation is reversible.
- Approval decisions are immutable; later decisions supersede, not erase.
- Published external posts cannot be rolled back in Mongo; use provider delete if supported or corrective content.
- Payment refund is a financial operation; do not “undo” by editing subscription alone.
- Campaign changes affecting published content are explicit and audited.

---

9. Agentic AI design

9.1 Principle

An agent is a planner/reasoner over typed, bounded tools. Backend domain services remain the policy enforcement point. **No unrestricted DB access, arbitrary HTTP, shell, raw social tokens or payment credentials.**

9.2 Runtime

```
User request / trigger
 → Agent Orchestrator
 → tenant authorization + policy
 → LLM planner
 → typed tool proposal
 → tool gateway (allowlist/schema/budget)
 → read/draft actions
 → human approval checkpoint
 → re-check policy + one-time approval
 → execution service/queue
 → audit + trace + notification
```

Agents never call platform APIs directly.

9.3 Agent catalogue

Agent	Goal and inputs	Tools	Approval / permissions	Evaluation
Brand Strategist	Brand, audience, goals, content	Read brand/content; propose guidelines	Read/draft; human approves brand changes	Consistency rubric and human rating
Content Planner	Campaign brief, calendar, channel mix	Read calendar; propose plan/slots	Cannot schedule directly	Completeness, feasibility, conflicts
Content Creator	Brief, brand, recommendations, channel rules	Recommendation, draft generation, validation	Draft only	Schema/platform validity, acceptance/edit rate
SEO/Growth Analyst	Authorized site content and available metrics	Content audit, topic/keyword suggestions, report draft	Read/recommend only	Evidence traceability, factuality
Campaign Manager	Objective, dates, content inventory	Draft/update campaign, propose assignments	No external activation without approval	Completion and override rate
Community Insights Analyst	Permitted metrics/comments	Aggregate, summarize, classify	Read-only; no replies	Classification quality and review
Performance Analyst	Normalized metrics	Query/compare/report	Read-only	Metric tests and factuality
Scheduler Assistant	Approved content/calendar constraints	Propose slots/check conflicts	Schedule requires approval initially	Conflict and missed-slot rate
Publishing Operator	Approved publication request	Enqueue publish, status/reconcile	Only after valid exact-action approval	Success, duplicate and reconciliation rate
Billing Assistant	Plan/usage/payment status	Read status, explain, prepare checkout	Cannot change plan/refund/spend; user checkout + server verification	Correctness and no unauthorized mutation

9.4 Tool boundaries

Example tools:

- `getBrandContext`
- `searchContent`
- `getAnalytics`
- `getProviderCapabilities`
- `draftContent`
- `createCampaignDraft`
- `proposeSchedule`
- `requestApproval`
- `executeApprovedPublish`
- `getPublicationStatus`

No generic fetch URL, arbitrary Mongo query, shell or raw provider API tool.

Every tool validates schema, derives tenant from authenticated context, checks role/ownership, enforces budget, redacts sensitive fields, times out and logs metadata.

9.5 Approval gates

Mandatory for publishing, deleting a live post, bulk email, external campaign activation, any paid spend/budget change/purchase, billing plan change/refund, workspace voice change, invitations/role changes and destructive data operations.

Approval binds exact action, content version/hash, target account/channel, scheduled time, cost/budget, approver, expiry and one-time execution ID. Any content change invalidates approval.

9.6 Agent observability and cost control

Persist run ID, tenant/actor/trigger, agent/model/prompt version, goal, input references, plan, tool names and argument hashes, results summary, approvals, token usage, estimated cost, duration, status, error and trace ID. Do not log secrets or unnecessary personal data.

Limits: max steps, wall time, token/cost budget, tool calls, draft count/recipients, tenant concurrency and provider circuit breakers.

Launch sequence: draft/recommendation agents first; planner and analytics next; approval-bound action agents last.

---

10. Phased implementation roadmap

The sequencing below follows the report's actual status. Do not reimplement fixes already reported complete unless regression tests fail.

Phase 0 — Baseline verification and evidence lock

Why: the report gives test totals but no commit SHA or raw run artifacts.

Frontend: run app, capture routes and empty/error/loading states, verify simulation labels. Backend: reproduce 449 tests; verify auth, credits, payment, settings, media, social and schedule endpoints; capture route inventory. ML: run 27 tests, explain skip, verify artifacts and health. Platform: run deployment verifier 10/10, build containers, verify probes.

Exit: exact commit SHA, lockfile hashes, CI logs and provider-path classification: real sandbox / real production / mocked / unavailable.

Phase 1 — Truthful capability states

Why: broadcast simulation and mock scheduling are explicit report limitations.

Frontend: show Available, Sandbox, Simulated, Needs approval, Disconnected and Reauthorization required. Backend: provider capability registry; standard publication DTO; mock adapters disabled in production.

Exit: simulation cannot be represented as live provider success.

Phase 2 — Social connection lifecycle

Frontend: connect, scope explanation, reauthorize/disconnect and health state. Backend: audit signed state/PKCE, callback allowlist, token refresh/revocation, key rotation, refresh lock, scopes/expiry, pause schedules on reauth.

Exit: connect → test publish → refresh → revoke/disconnect proven for each supported provider in permitted environment.

Phase 3 — Durable scheduling and publishing

Frontend: replace mock calendar with API-backed schedule, edit/cancel and retry details. Backend: verify queue; introduce BullMQ/Redis if absent/incomplete; persistent schedules/publications; idempotency; quota-aware retries; dead-letter; timezone UTC; cancellation race.

Exit: survives API restart, no duplicate post, ambiguous outcomes reconciled.

Phase 4 — Workspace/brand tenancy

Frontend: workspace/brand switcher, invite and role-aware nav. Backend: additive Workspace/Membership, backfill, workspace-scoped queries/jobs, policy module and audit events.

Constraint: no rewrite of existing User/Job models; use additive collections/adapters.

Exit: cross-workspace isolation tests for all resources and worker actions.

Phase 5 — Content lifecycle and approvals

Frontend: content library, editor, platform previews, version history, approval inbox/comments. Backend: canonical lifecycle, immutable versions, approval requests/decisions, content-to-campaign/schedule links, deletion semantics.

Exit: draft → edit → approve → schedule → publish is auditable and version-bound.

Phase 6 — Campaign management

Frontend: campaign list, brief, calendar, deliverables, owner/reviewer. Backend: campaign services, assignments, state transitions, audit and aggregation. No paid spend.

Exit: campaign can be planned, populated, approved, scheduled and reported.

Phase 7 — Analytics ingestion

Why: report defers live analytics to v1.2.

Frontend: overview/channel/post/campaign analytics, freshness and provenance. Backend: provider metric adapters, quota-aware polling, normalized definitions, snapshots, deduplication and retention.

Exit: every metric has source/definition/collection time; unsupported is not shown as zero.

Phase 8 — Recommendations and SEO/growth

Frontend: recommendation cards with rationale/evidence, accept/edit/dismiss; SEO audit/topic ideas. Backend/ML: persist model version/input/output, expose fallback provenance, add content-based SEO recommendations.

Exit: every recommendation traceable to data/model/prompt version; acceptance creates proposal/draft only.

Phase 9 — Draft-first agents

Frontend: AI task composer, run timeline, review and cost. Backend: orchestrator, policy engine, tool gateway; Brand Strategist, Content Planner, Creator and Analytics Analyst; limits/traces/redaction.

Exit: agents cannot publish/spend under prompt injection or permission tests.

Phase 10 — Approval-bound action agents

Frontend: confirmation of exact content/channel/account/time/action. Backend: action hash, one-time approval, expiry/recheck, Publishing Operator and idempotent execution.

Exit: no execution without valid approval; edits invalidate approval.

Phase 11 — Team collaboration

Frontend: role management, invites, team activity and audit. Backend: approved role matrix, invitation expiry, role audit; SSO only after enterprise demand.

Exit: RBAC matrix tests across API, frontend and workers.

Phase 12 — Reliability, privacy and scale

Load test API/ML/queue/publish/analytics; dashboards/alerts/SLOs; backup restore; provider quota tests; queue restart; export/delete/retention; key rotation; cost attribution.

Exit: measured capacity, recovery time and cost documented; no known critical tenant isolation/authorization defects.

Phase 13 — General availability expansion

Staged rollout, provider approvals/live credentials, Razorpay live KYC/keys, support and incident process, legal docs/DPAs, kill switches and margin review.

Exit: founder signs scope, legal readiness, support coverage, unit economics and release gates.

11. Testing and release gates

Test layer	Proves	Required focus
Unit	business rules	entitlement, roles, state machines, idempotency, prompt/output validation
Integration	modules + DB/provider behavior	OAuth, credits, billing, schedule, publish
Contract	boundaries agree	frontend/API, Node/ML, provider adapter
E2E	real journey	onboarding → connect → create → approve → schedule → publish → analytics
Security	access boundaries	tenant isolation, IDOR, OAuth replay, token leakage, prompt injection, approval bypass
Resilience	recovery	provider outage, queue restart, DB outage, expired token, duplicate callback
Load	capacity/latency	API, generation, queue, ML, analytics
ML/agent eval	quality and safety	groundedness, fallback, tool authorization, cost and no-action constraints

Mandatory regression: CON-01, GEN-01, SEC-03/04, SEC-01/02, E2E-01, FE-02, FE-03, FE-05 plus simulated-publish state, persistent scheduling, idempotency, token refresh, tenant isolation, approval hash invalidation, agent no-approval denial and analytics freshness.

Release checklist:

- tests green; skipped tests explained;
- provider sandbox evidence and production approvals;
- secrets rotated/managed;
- simulation disabled in production;
- migration dry run and backup;
- health/readiness pass;
- rollback tested;
- alerts enabled;
- support owner assigned;
- product copy matches real capability.

12. Founder decisions and open questions

ID	Choice	Recommended default	Consequence
F-01	Initial ICP	Creator + SMB first; agencies next	Aligns current onboarding; limits early RBAC scope
F-02	■4,999 tier name	Business until enterprise governance exists	Avoids overpromise
F-03	Workspace semantics	One default workspace/account; agency multi-brand	Simple onboarding + tenant boundary
F-04	Roles	Admin, Editor, Approver, Viewer	Small permission matrix
F-05	GA providers	Only approved providers with real E2E proof	No fake live capability
F-06	Paid ads/spend	Exclude initially; budget is planning metadata	Avoid financial risk
F-07	Agent autonomy	Draft/recommend by default; approval for side effects	Protects brand and money
F-08	Training on customer data	Off by default; explicit opt-in after legal review	Protects IP/privacy
F-09	Analytics freshness	Provider-permitted polling + last-updated label	No false real-time claim
F-10	SEO sources	Content-based recommendations first	Avoids fabricated search volume
F-11	Video generation	Defer/separate add-on	Report notes GPU latency/cost
F-12	Data region	Select based on customer geography/legal needs	Requires market decision
F-13	SLA	No enterprise SLA until staffing/monitoring supports it	Avoids contractual overcommitment
F-14	Agency billing	Workspace + seat/brand limits; validate willingness-to-pay	Aligns price with value/cost

Evidence questions:

1. Which provider apps have live production approval, and for which exact scopes?
2. Does each provider support refresh/revocation in the current implementation?
3. Is schedule API backed by durable queue today or still mock-backed?
4. What object storage backs media?
5. Actual MAU, connected accounts, generation and publish volumes?
6. Average Groq tokens/cost per generation?
7. Which analytics metrics are available for each approved account type?
8. Actual Mongo schema/index list and query profile?
9. What are SEC-16/18/19?
10. What privacy/retention/DPA commitments have been published?

13. Risk register

Risk	Impact	Mitigation
Platform approval/policy change	Publishing/analytics unavailable	Capability matrix, staged support, regular compliance review
Simulation appears real	Trust and brand damage	Environment lock and truthful statuses
Token expiry/revocation	Missed posts	Refresh lock, reauthorization state, alerts
Cross-tenant leak	Severe legal/reputation	Workspace scope and negative tests
Bad agent output	Public brand harm	Draft-first, approval hash, preview, kill switch
LLM cost spike	Margin erosion	Credits, budgets, output limits, per-tenant caps
Provider quotas	Backlog	Provider-aware scheduling/backoff
Analytics inconsistency	Bad decisions	Metric definitions, provenance and freshness
Migration breaks customers	Data loss/outage	Additive migration, dry run, reconciliation, backup
Scope expansion	Slow delivery	Milestone gates and explicit MVP
SEO overclaim	Misrepresentation	Label suggestions, source evidence, no rank guarantees
Agent loops	Cost/operational risk	Step/time/cost limits and tool allowlist

14. Target capability matrix

Capability	Report baseline	Target state	Priority
Shared SaaS frontend	Implemented	Extend	P0
Auth/session	Implemented/tested	Maintain regression/security	P0
Brand onboarding	Implemented	Workspace context	P0
AI generation	Implemented	Content/version/approval lifecycle	P0
ML recommendations	Service + fallback	Provenance and acceptance UX	P1
OAuth	UI/flows reported	Provider lifecycle verified	P0
Token encryption	AES-GCM reported	Key lifecycle/rotation evidence	P0
Publishing	Partial/provider-dependent	Approved adapters + idempotency	P0
Scheduling	Mock-tested UI	Durable scheduler/workers	P0
Media	Implemented	Validate storage/quotas/tenant scope	P1
Campaigns	Not described as implemented	Campaign domain	P1
Approvals	Not described as implemented	Human workflow	P0 for agents/teams
Analytics	Deferred	Provider ingestion	P1
SEO/growth	Not described	Evidence-labelled recommendations	P2
Multi-brand	Schema reported ready; UI one brand	Workspace/brand switcher	P1
Team/RBAC	Deferred	Memberships and roles	P1
Agentic AI	Not described as implemented	Bounded draft-first agents	P1
Paid spend	Not described	Exclude pending approval model	Later
Video/Reels	Deferred	Separate async pipeline	Later

15. Definition of done: “one control centre”

A meaningful control-centre release lets a user:

1. sign in to one shared SaaS site;
2. create/select workspace and brand;
3. securely connect an approved social account;

4. inspect connection state, scopes and reauthorization;
5. create/edit/version/organize content;
6. attach media;
7. group content into campaigns;
8. request AI recommendations and drafts;
9. review and approve;
10. schedule with timezone awareness;
11. publish through a real provider integration;
12. see truthful receipts and failures;
13. review provider-backed analytics with freshness;
14. receive evidence-labelled SEO/organic-growth recommendations;
15. collaborate under role permissions;
16. inspect agent plans, tools and human approvals;
17. manage plan, usage and payment;
18. export/delete data according to published policy.

For agentic workflows: bounded goals/tools, tenant authorization, no publish/spend without valid human approval, observable runs and cost limits.

16. Final engineering directive

The report describes a substantially hardened MVP: React 19 SPA, Node 22/Express API, MongoDB 7, Python FastAPI recommender, cookie sessions, encrypted social tokens, server-authoritative Razorpay test flow, credit metering, Docker artifacts and 513 reported passing tests.

Do not start by rewriting models or replacing the stack. Validate audit claims against the current commit, close explicitly simulated/mock/deferred gaps, and establish tenant-safe content/publishing/approval lifecycles.

Recommended order:

1. reproduce baseline and record commit/test evidence;
2. make simulation/provider capability states truthful;
3. complete OAuth/token lifecycle;
4. make scheduling and publishing durable/idempotent;
5. add workspace tenancy without rewriting existing models;
6. add content versions and human approvals;
7. implement campaigns;
8. implement provider-backed analytics;
9. add evidence-based SEO/organic recommendations;
10. introduce draft-first agents, then approval-bound action agents;
11. complete privacy, cost, load and operational readiness;
12. expand rollout only after provider, security, reliability and unit-economics gates pass.

Optimize for trustworthy outcomes, not feature count. A few providers working end-to-end are more valuable than ten simulated integrations. A safe agent that drafts and asks for approval is more valuable than an unrestricted autonomous agent. A tested tenant boundary is more valuable than a “multi-brand ready” label.

Any deviation from this source of truth should be recorded as an Architecture Decision Record containing context, options, decision, rationale, risks, migration impact, owner and review date.